



[INICIO](#) / [INCIBE-CERT](#) / [Blog](#) / RFC 3227 - Directrices para la recopilación de evidencias y su almacenamiento

RFC 3227 - Directrices para la recopilación de evidencias y su almacenamiento

Fecha de publicación 18/06/2014

Autor

Asier Martínez (INCIBE)



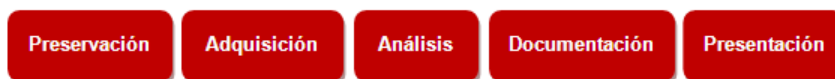
A día de hoy, como reflejan los **datos** , el volumen de incidentes relacionados con la seguridad informática es muy grande y las perspectivas no hacen pensar que este hecho vaya a mejorar.

Entre todos ellos destacan: robo de información, **fraude**, **malware** , **accesos no autorizados** , uso inapropiado de recursos, propiedad intelectual, denegación de servicio o extorsión.



En parte motivado para hacerles frente, y como consecuencia del principio de intercambio de **Locard** , el cuál sentó las bases de la ciencia forense, y que indica que: “siempre que dos objetos entran en contacto transfieren parte del material que incorporan al otro objeto”, surge el concepto de análisis forense digital. Este término hace referencia a un conjunto de procedimientos de recopilación y análisis de evidencias que se realizan con el fin de responder a un incidente relacionado con la seguridad informática. Es decir, mediante este proceso se pretende responder a las siguientes preguntas: ¿qué?, ¿dónde?, ¿cuándo?, ¿por qué?, ¿quién? y ¿cómo?

Pese a la gran diversidad de incidentes, los pasos a seguir durante el proceso de análisis forense son comunes, y corresponden a los siguientes:



Para ello, existen diferentes metodologías o guías, si bien todas recogen aspectos y pautas similares. Algunas de las más destacadas son las siguientes:

- ◆ Guidelines for the best practices in the forensic examination of digital technology
- ◆ Electronic Crime Scene Investigation: A Guide for First Responders
- ◆ Forensic Examination of Digital Evidence: A Guide for Law Enforcement
- ◆ UNE 71506 - Metodología para el análisis forense de las evidencias electrónicas
- ◆ Good Practice Guide for Computer-Based Electronic Evidence
- ◆ RFC 3227 «Guidelines for Evidence Collection and Archiving» o Directrices para la recopilación de evidencias y su almacenamiento

A continuación, se detalla el RFC 3227 por tratarse de uno de los referentes, el cual refleja, desde un punto de vista teórico y bastante completo, el proceso de actuación y las pautas que se deben seguir a la hora de realizar un análisis de este tipo.

RFC3227 - Directrices para la recolección de evidencias y su almacenamiento

Los RFC «Request For Comments» son documentos que recogen propuestas de expertos en una materia concreta, con el fin de establecer por ejemplo una serie de pautas para llevar a cabo un proceso, la creación de estándares o la implantación de algún protocolo. El RFC 3227 es un documento que recoge las directrices para la recopilación de evidencias y su almacenamiento, y

puede llegar a servir como estándar de facto para la recopilación de información en incidentes de seguridad.

Estos son los puntos más importantes relacionados con dicho proceso:

Principios durante la recolección de evidencias

- ◆ Capturar una imagen del sistema tan precisa como sea posible.
- ◆ Realizar notas detalladas, incluyendo fechas y horas indicando si se utiliza horario local o UTC.
- ◆ Minimizar los cambios en la información que se está recolectando y eliminar los agentes externos que puedan hacerlo.
- ◆ En el caso de enfrentarse a un dilema entre recolección y análisis elegir primero recolección y después análisis.
- ◆ Recoger la información según el orden de volatilidad (de mayor a menor).
- ◆ Tener en cuenta que por cada dispositivo la recogida de información puede realizarse de distinta manera.

A. Orden de volatilidad

El orden de volatilidad hace referencia al período de tiempo en el que está accesible cierta información. Es por ello que se debe recolectar en primer lugar aquella información que vaya a estar disponible durante el menor período de tiempo, es decir, aquella cuya volatilidad sea mayor.

De acuerdo a esta escala se puede crear la siguiente lista en orden de mayor a menor volatilidad:

- ◆ Registros y contenido de la caché.
- ◆ Tabla de enrutamiento, caché ARP, tabla de procesos, estadísticas del kernel, memoria.
- ◆ Información temporal del sistema.
- ◆ Disco
- ◆ Logs del sistema.
- ◆ Configuración física y topología de la red.
- ◆ Documentos.

B. Acciones que deben evitarse

Se deben evitar las siguientes acciones con el fin de no invalidar el proceso de recolección de información ya que debe preservarse su integridad con el fin de que los resultados obtenidos puedan ser utilizados en un juicio en el caso de que sea necesario:

- ◆ No apagar el ordenador hasta que se haya recopilado toda la información.
- ◆ No confiar en la información proporcionada por los programas del sistema ya que pueden haberse visto comprometidos. Se debe recopilar la información mediante programas desde un medio protegido como se explicará más adelante.
- ◆ No ejecutar programas que modifiquen la fecha y hora de acceso de todos los ficheros del sistema.

C. Consideraciones sobre la privacidad

- ◆ Es muy importante tener en consideración las pautas de la empresa en lo que a privacidad se refiere. Es habitual solicitar una autorización por escrito de quien corresponda para poder llevar a cabo la recolección de evidencias. Este es un aspecto fundamental ya que puede darse el caso de que se trabaje con información confidencial o de vital importancia para la empresa, o que la disponibilidad de los servicios se vea afectada.
- ◆ No hay que entrometerse en la privacidad de las personas sin una justificación. No se deben recopilar datos de lugares a los que normalmente no hay razón para acceder, como ficheros personales, a menos que haya suficientes indicios.

Procedimiento de recolección

El procedimiento de recolección debe de ser lo más detallado posible, procurando que no sea ambiguo y reduciendo al mínimo la toma de decisiones.

A. Transparencia

Los métodos utilizados para recolectar evidencias deben de ser transparentes y reproducibles. Se debe estar preparado para reproducir con precisión los métodos usados, y que dichos métodos hayan sido testados por expertos independientes.

B. Pasos

- ◆ ¿Dónde está la evidencia? Listar qué sistemas están involucrados en el incidente y de cuáles de ellos se deben tomar evidencias.
- ◆ Establecer qué es relevante. En caso de duda es mejor recopilar mucha información que poca.
- ◆ Fijar el orden de volatilidad para cada sistema.
- ◆ Obtener la información de acuerdo al orden establecido.
- ◆ Comprobar el grado de sincronización del reloj del sistema.
- ◆ Según se vayan realizando los pasos de recolección preguntarse qué más puede ser una evidencia.
- ◆ Documentar cada paso.
- ◆ No olvidar a la gente involucrada. Tomar notas sobre qué gente estaba allí, qué estaban haciendo, qué observaron y cómo reaccionaron.

El procedimiento de almacenamiento

A. Cadena de custodia

Debe estar claramente documentada y se deben detallar los siguientes puntos:

- ◆ ¿Dónde?, ¿cuándo? y ¿quién? descubrió y recolectó la evidencia.
- ◆ ¿Dónde?, ¿cuándo? y ¿quién? manejó la evidencia.
- ◆ ¿Quién ha custodiado la evidencia?, ¿cuánto tiempo? y ¿cómo la ha almacenado?
- ◆ En el caso de que la evidencia cambie de custodia indicar cuándo y cómo se realizó el intercambio, incluyendo número de albarán, etc.

B. Dónde y cómo almacenarlo

Se debe almacenar la información en dispositivos cuya seguridad haya sido demostrada y que permitan detectar intentos de acceso no autorizados.

Herramientas necesarias

Existen una serie de pautas que deben de ser seguidas a la hora de seleccionar las herramientas con las que se va a llevar a cabo el proceso de recolección:

- ◆ Se deben utilizar herramientas ajenas al sistema ya que éstas pueden haberse visto comprometidas, principalmente en los casos de malware.
- ◆ Se debe procurar utilizar herramientas que alteren lo menos posible el escenario, evitando el uso de herramientas de interfaz gráfico y aquellas cuyo uso de memoria sea grande.
- ◆ Los programas que se vayan a utilizar para recolectar las evidencias deben estar ubicados en un dispositivo de sólo lectura (CDROM, USB, etc.).
- ◆ Se debe preparar un conjunto de utilidades adecuadas a los sistemas operativos con los que se trabaje.
- ◆ El kit de análisis debe incluir los siguientes tipos de herramientas:
 - ◆ Programas para listar y examinar procesos.
 - ◆ Programas para examinar el estado del sistema.
 - ◆ Programas para realizar copias bit a bit.

Conclusiones

A la hora de enfrentarse a un incidente de seguridad hay que tener muy claro las acciones que se deben realizar, siendo muy meticuloso y detallando en todo momento dicho proceso de manera minuciosa. Así mismo, se debe realizar el proceso procurando ser lo menos intrusivo posible con el fin de preservar el sistema en su estado original, y siguiendo las pautas indicadas en alguna de las metodologías o guías anteriormente indicadas o similares.

Finalmente, se debe tener presente que los requisitos o pautas a seguir a la hora de realizar un análisis forense digital que vaya a derivar en un proceso legal varían dependiendo del país, ya que no existe una legislación común. De todas formas, se debe tender a seguir las indicaciones establecidas en alguna metodología como el RFC 3227 con el fin de que dicho proceso sea realizado de una manera rigurosa.



Tags INCIBE-CERT

